

匿名网络中的流量分析与滥用检测研究：从 Tor 网络到匿名化僵尸网络

梁峻玮 田丰睿 李青宇
PB23071341 PB23071318 PB23071316

2026 年 5 月 30 日

摘要

在此撰写摘要。

1 引言

1.1 研究背景与动机

随着 TLS、HTTPS 等加密协议的普及，网络通信内容的机密性已经在很大程度上得到保护。然而，内容加密并不等价于通信隐私的充分保护。即使攻击者无法解密具体载荷，通信双方的网络位置、连接时间、包长分布、方向序列、突发模式以及访问频率等元数据仍可能暴露用户行为和通信关系。Sasy 和 Goldberg 将这类问题概括为元数据保护通信系统（metadata-protecting communication systems, MPCs）的核心目标，即不仅要隐藏消息内容，还要尽可能削弱攻击者对发送者、接收者及二者关联关系的推断能力 [1]。从这一角度看，匿名网络并不是传统加密通信的替代品，而是在内容机密性之外进一步缓解通信关系泄露和流量侧信道的一类协议与系统机制。

匿名通信研究最早可以追溯到 Chaum 提出的 Mix 网络。该工作通过批处理、重排序和级联 Mix 打破输入消息与输出消息之间的对应关系，奠定了匿名通信对抗流量分析的基本范式 [2]。随后，洋葱路由进一步将匿名通信推向低延迟交互式场景，Tor 作为第二代洋葱路由系统，通过多跳电路、分层加密、目录服务和汇合点机制，在可用性、效率和匿名性之间作出工程化折中，成为目前最具代表性的匿名通信网络之一 [3]。这种设计使得单个中继难以同时获知通信源和通信目的，但低延迟交互式通信也保留了较多可观测的流量形状特征，为后续的网站指纹识别、流量相关和去匿名化攻击留下了空间。

近年来，匿名网络研究的重点逐渐从单纯构造匿名通信机制，转向围绕真实部署环境下的攻防对抗、可用性约束和安全边界展开。一方面，攻击技术不断利用加密流量中的时序和方向模式提升推断能力。例如，Shen 等人针对 Tor 网站指纹防御提出鲁棒流量表示方法，说明已有填充类防御仍可能保留可被学习的结构性泄露 [4]。Zhao 等人进一步将 Tor 指纹攻击推进到细粒度网页级识别，表明攻击目标已经从“访问了哪个站点”扩展到“访问了站点中的哪个页面” [5]。另一方面，真实环境评估也逐渐受到重视，Jansen 等人通过真实 Tor 流量轨迹构建数据集，指出以往基于合成数据的评估可能难以充分反映开放世界中的访问分布、基础率和会话复杂性 [6]。这些工作共同表明，匿名网络的安全性不能仅在理想化协议模型中讨论，而必须结合真实流量、真实用户行为和实际部署约束进行分析。

匿名网络的另一重要特征是其双重用途。一方面，它为新闻工作者、研究人员、政治异见者和普通用户提供了规避审查、保护访问隐私和降低追踪风险的工具。另一方面，匿名性也可能被恶意行为者利用，用于隐藏钓鱼站点、暗网服务、命令与控制（Command and Control, C&C）基础设施以及僵尸网络运营者的真实位置。因此，匿名网络研究不仅需要回答“如何提升匿名性”，还必须进一步讨论“如何在破坏合法匿名性的前提下识别和治理滥用”。这正构成了本文从匿名网络基础、Tor 网络攻防到僵尸网络匿名化与检测进行系统调研的主要动机。

1.2 研究范围与思路

本文围绕“匿名网络、Tor 网络与僵尸网络”这一主题展开调研，聚焦于三类问题：匿名通信机制如何隐藏通信关系，Tor 网络在真实部署中面临哪些流量分析与去匿名化威胁，以及僵尸网络等恶意活动如何利用匿名网络隐藏基础设施。

在匿名通信基础方面，本文首先从元数据保护通信系统的视角出发，梳理匿名通信试图保护的對象，包括发送者身份、接收者身份、通信双方关联关系以及多次通信行为之间的不可链接性 [1]。在此

基础上,本文比较 Mix 网络、洋葱路由和 DC-Nets 等代表性技术路线。Chaum 提出的 Mix 网络通过批处理和重排序降低输入、输出消息之间的可链接性 [2],而 Tor 所代表的低延迟洋葱路由则通过多跳电路和分层加密支持交互式匿名访问 [3]。两类技术分别体现了匿名通信设计中的不同取舍。前者通常具有更强的流量混淆能力,但延迟和可部署性成本较高。后者更适合 Web 浏览等交互式场景,却更容易暴露包长、方向和时序等可被学习的流量特征。

在 Tor 网络攻防方面,本文重点讨论低延迟匿名网络在真实环境下面临的攻击与防御问题。近年来,网站指纹识别、流量相关攻击和针对洋葱服务的去匿名化技术不断发展,使得攻击者即使无法解密通信内容,也可能通过加密流量的形状特征推断用户访问目标或关联通信双方。与此相对应,流量填充、流量整形、对抗式防御和差分隐私机制被用于削弱流量侧信道,但这些防御通常会引入额外带宽、延迟或部署复杂性。因此,本文在研究 Tor 攻防技术时,不仅关注具体攻击或防御方法本身,也关注其威胁模型、评估数据集、现实可部署性和安全性的权衡。

在僵尸网络匿名化与检测方面,本文将 Tor 等匿名网络视为一种可能被滥用的基础设施,分析其在隐藏 C&C 服务器、规避追踪和提高恶意活动韧性方面的作用。与传统僵尸网络检测相比,匿名网络环境下的检测问题更加复杂:防御者既需要识别恶意流量和匿名化 C&C 行为,又必须避免破坏合法用户的匿名通信需求。因此,本文将僵尸网络部分置于匿名网络双重用途的框架下讨论,重点分析隐私保护与安全治理之间的张力。

1.3 论文组织结构

本文后面的章节组织如下:

第二章介绍匿名网络技术基础,首先界定匿名通信所保护的對象和典型威胁模型,随后梳理 Mix 网络、洋葱路由、DC-Nets 等代表性技术路线,并从匿名性、时延、带宽开销和可部署性等维度分析不同机制之间的权衡关系,为后续讨论 Tor 网络攻防提供概念基础。

第三章以 Tor 网络为核心,首先介绍其系统架构、通信电路和洋葱服务机制,随后围绕网站指纹识别、流量相关攻击、带宽操纵攻击和洋葱服务去匿名化等方向总结近年来的攻击技术进展,并进一步分析流量填充、流量整形和协议层防御等对抗方法的有效性与局限性。

第四章讨论僵尸网络对匿名网络的利用及其检测问题。首先概述僵尸网络的基本架构与 C&C 通信模式,然后重点分析恶意活动如何借助 Tor 洋葱服务隐藏控制基础设施,并从流量特征、行为模式和机器学习检测等角度梳理匿名环境下的检测方法及其挑战。

第五章在前述分析基础上进行系统化讨论,进一步总结匿名网络、Tor 网络与僵尸网络之间的技术关联,提炼匿名通信系统面临的核心矛盾,包括低延迟可用性与抗流量分析能力之间的矛盾、隐私保护与滥用治理之间的矛盾,以及真实部署评估与理想化安全模型之间的差距。

第六章对全文进行总结,并展望匿名网络攻防研究在真实流量测量、可部署防御、隐私保护型滥用检测和安全治理机制等方面的未来发展方向。

2 匿名网络技术基础

匿名网络的核心目标并不是单纯加密通信内容,而是在通信内容已经受到加密保护的基础上,进一步隐藏通信双方的身份、通信关系以及由流量模式暴露出的行为特征。匿名通信系统关注的是网络层和流量层的元数据泄露问题,包括谁在通信、与谁通信、何时通信以及多次通信行为之间是否可以被关联。Sasy 和 Goldberg 指出不同匿名通信机制在隐私保证、系统假设和可部署性方面存在显著差异 [1]。因此,在分析 Tor 网络及其攻防技术之前,有必要先明确匿名通信的保护目标、攻击者能力以及主要技术路线。

本章围绕匿名网络的基础机制展开,从发送者匿名性、接收者匿名性和通信不可链接性三个层面界定匿名通信的基本目标,并结合被动监听、恶意中继、局部网络观察和全局攻击者等模型说明匿名网络所面临的典型威胁。同时,梳理了 Mix 网络、洋葱路由和 DC-Nets 等代表性技术路线,比较它们在匿名性、延迟、带宽开销和部署复杂度方面的差异。在最后也进一步讨论了匿名网络设计中的核心权衡。

2.1 匿名通信的目标与威胁模型

匿名通信系统试图保护的對象可以分为三个层次。第一是发送者匿名性,攻击者即使能够观察网络中的部分通信流量,也难以确定某条消息或某次连接究竟由哪个用户发起。第二是接收者匿名性,通

信目标或服务提供方的身份不应轻易暴露给观察者。第三是不可链接性，攻击者难以将同一用户的多次访问、同一会话中的多个流量片段，或某个用户与某个访问目标之间建立稳定关联。相比传统加密协议，匿名通信更关注通信关系和访问模式等元数据，这些元数据即使在内容加密后仍然可能通过包长、方向、时序和突发结构泄露用户行为。

早期匿名通信研究已经意识到通信关系本身可能成为敏感信息。Chaum 提出的 Mix 网络通过批处理、重排序和转发打破输入消息与输出消息之间的对应关系，从而降低观察者对发送者和接收者关系的推断能力 [2]。洋葱路由则转向低延迟交互式通信场景，Tor 通过多跳电路和分层加密使得单个中继节点无法同时获知通信源和通信目的 [3]。这两类机制体现了匿名通信目标的不同侧重，Mix 网络更强调打破端到端流量关联，洋葱路由则更强调在可接受延迟下提供可部署的匿名访问能力。

匿名通信系统的安全性高度依赖威胁模型。最基本的攻击者是本地被动观察者，例如互联网服务提供商、局域网监听者或出口链路上的监测者。此类攻击者不修改流量，但可以记录连接时间、包长序列和流量方向，并据此进行网站指纹识别或访问行为推断。更强的攻击者可能控制匿名网络中的部分节点。例如在 Tor 中，恶意入口节点可能观察用户进入网络的流量，恶意出口节点可能观察离开匿名网络的明文或目标连接信息，而多个恶意节点的协同则可能增加端到端关联风险。对于 Mix 网络而言，部分混合节点或 provider 被攻陷也会削弱匿名集规模和流量混合效果。

进一步而言，局部网络攻击者可以观察多个自治系统、交换点或网络路径上的流量，从而尝试进行跨链路相关分析。全局被动攻击者则被假设能够观察整个网络中的所有输入和输出流量，是匿名通信研究中常用但较强的理论模型。在全局观察条件下，低延迟匿名网络尤其脆弱，因为系统为了保证交互性通常不会引入足够大的延迟、批处理或覆盖流量来完全打散输入输出时序关系。与被动攻击者相比，主动攻击者还可以延迟、丢弃、注入或操纵数据包，通过人为改变流量模式来放大可观测特征，甚至诱导特定路径选择或服务行为。

因此，匿名网络的安全性不能脱离具体攻击者能力进行讨论。同一系统在不同威胁模型下可能呈现出完全不同的安全边界，在局部被动观察者模型下，Tor 可以通过多跳电路隐藏用户与目标之间的直接关联。但在更强的流量相关或全局观察模型下，其低延迟设计仍可能暴露端到端统计相关性。类似地，Mix 网络通过延迟、重排序和覆盖流量增强匿名性，但这些机制又会带来额外时延、带宽和部署成本。匿名通信系统的设计本质上是在攻击者能力、隐私保证和系统可用性之间寻找平衡，这也构成了后续比较不同匿名技术路线的基础。

2.2 匿名网络的主要技术路线

围绕通信关系隐藏这一目标，匿名网络形成了多条技术路线。其中，Mix 网络和洋葱路由是最具代表性的两类机制。前者通过延迟、批处理和重排序削弱输入输出流量之间的对应关系，通常能够提供更强的流量混淆能力，后者则通过多跳转发和分层加密隐藏通信路径，在牺牲部分抗流量分析能力的同时获得较低延迟和较高可部署性。除此之外，DC-Nets、匿名广播、匿名凭证和私有用户发现等机制也从不同角度扩展了匿名通信的应用边界。

2.2.1 Mix 网络

Mix 网络是匿名通信研究的经典起点。Chaum 最早提出的 Mix 机制通过收集一批输入消息、剥离加密层、打乱顺序并转发输出，使外部观察者难以建立输入消息与输出消息之间的对应关系，在级联 Mix 中，只要路径上至少存在一个诚实 Mix 节点，就可以在在一定程度上保护通信关系不被追踪 [2]。这一思想的核心在于主动改变流量的时序和顺序结构，而不是仅依赖内容加密隐藏通信信息。因此，Mix 网络天然适合对抗强观察者和流量相关攻击，但代价是引入额外排队延迟、批处理等待和系统同步开销，使其早期更适合电子邮件等非实时通信场景。

为缓解传统 Mix 网络延迟较高、难以支持交互式应用的问题，后续研究尝试将 Mix 机制推向低延迟和可部署方向。Loopix 采用 Poisson mixing、分层拓扑和自注入 loop 覆盖流量，在保留 Mix 网络输入输出混淆能力的同时支持双向匿名通信 [7]。Rahimi 等人提出 LARMix，通过延迟感知路由和地理位置聚类降低 Mix 网络中的传播延迟，使 Mix 网络从“强匿名但高延迟”的理论机制进一步走向可用性优化 [8]。LAMP 进一步针对 LARMix 在大规模网络下计算开销较高、难以直接部署的问题，提出轻量级路由策略，在降低端到端延迟的同时显著减少路由计算成本 [9]。这些工作说明，现代 Mix 网络研究已经不再只关注匿名性本身，而是转向匿名性、延迟、计算开销和部署复杂度的联合优化。

除了路由层面的延迟优化, Mix 网络还需要考虑不同应用流量共同存在时的匿名性变化。Ben Guirat 等人提出 Beta-Mixing 分析框架, 研究连续 Mix 网络中不同延迟需求流量混合时的匿名性影响, 指出小规模流量类别在与大规模流量混合后可能获得更大的匿名集, 从而提升整体匿名性 [10]。这一结果表明, Mix 网络的匿名性不仅由单个节点或单条路径决定, 也与全网流量组成、延迟分布和覆盖流量策略密切相关。Oldenburg 等人提出 MixMatch, 对部署型 Mix 网络中的流匹配攻击进行研究, 说明即使系统引入混合、延迟和覆盖流量, 攻击者仍可能利用统计特征尝试关联输入输出流量 [11]。因此, Mix 网络虽然相较于低延迟洋葱路由具有更强的抗流量分析潜力, 但其安全性仍取决于具体流量模型、部署条件和攻击者观察能力。

2.2.2 洋葱路由与 Tor

洋葱路由则代表了另一类设计取向, 其更强调在低延迟条件下隐藏通信路径。基本思想是客户端选择一条由多个中继节点组成的路径, 并对消息进行多层加密, 每个中继节点只能解开属于自己的一层加密, 获知前一跳和后一跳, 却无法同时知道通信源和最终目的。Tor 是这一思想最成功的工程化实现。Dingledine 等人提出的第二代 Tor 通过递增式电路构建、固定大小 cell、目录服务、SOCKS 接口和汇合点机制, 使洋葱路由能够支持 Web 浏览等交互式应用, 并在匿名性和可用性之间取得可部署的折中 [3]。

然而, Tor 的低延迟设计也决定了它无法像高延迟 Mix 网络那样充分打乱输入输出时序关系。为了保证交互式体验, Tor 通常不会引入大规模批处理、长时间延迟或高强度覆盖流量, 因此包方向、包长序列、突发模式和会话长度等流量形状特征仍然可能被攻击者利用。这也是网站指纹识别、流量相关攻击和洋葱服务去匿名化攻击长期以 Tor 为主要研究对象的重要原因之一。

从协议基础来看, 洋葱路由的安全性不仅依赖路径选择和中继假设, 也依赖底层数据包格式与密码学构造。Sphinx 包格式被广泛用于洋葱路由和 Mix 网络场景, 其目标是在隐藏路径信息的同时支持逐跳处理和回复机制。Scherer 等人重新审视 Sphinx 的可证明安全性, 指出原有证明假设存在不足, 并在更严格的模型下给出修正分析 [12]。进一步地, 同一研究线还提出面向全局对手的可证明安全洋葱路由框架, 从服务设置、接收者信任、负载完整性和回复机制等维度刻画不同洋葱路由变体的安全边界 [13]。这些工作说明, 匿名网络的安全性不能只从系统架构层面理解, 也需要结合密码协议模型和攻击者能力进行形式化分析。

2.2.3 其他匿名通信机制

除 Mix 网络和洋葱路由外, DC-Nets 也提供了另一种匿名通信思路。Chaum 提出的 Dining Cryptographers 网络通过参与者之间共享随机比特并公开异或结果, 实现信息论意义上的发送者匿名性 [14]。这类机制在理论上提供很强的匿名保证, 但通常面临参与者规模、通信开销、碰撞处理和恶意参与者干扰等问题, 因此更适合小规模或特定安全需求场景。近年来, 匿名广播、私有用户发现和可问责匿名通信等方向也在继续发展。例如, Pudding 关注匿名网络中的私有用户发现问题, 试图避免用户查找过程泄露联系人关系 [15]。Gyges 则探索在匿名广播中引入可问责机制, 以缓解匿名通信被滥用后的追踪困难 [16]。这些工作表明, 匿名通信研究已经从单一的隐藏通信双方扩展到更复杂的系统功能, 如用户发现、滥用追责和应用层隐私保护。

不同匿名技术路线体现了不同的设计取舍, Mix 网络通过延迟、重排序和覆盖流量增强抗流量分析能力, 但需要承担额外时延和带宽开销。洋葱路由通过低延迟多跳转发实现大规模部署, 却保留了更多可被学习的流量形状特征。DC-Nets 和匿名广播机制能够提供更强的理论匿名性或特殊功能, 但往往受限于可扩展性和部署复杂度。正是这些差异, 使得匿名网络的研究不能停留在抽象安全定义上, 而需要进一步分析具体系统在真实网络环境中的攻击面、防御成本和可部署性。

2.3 匿名性、性能与可部署性的权衡

匿名网络的设计并不能单纯追求匿名性, 而需要在匿名性、时延、带宽开销、计算开销和部署复杂度之间进行折中。一般来说, 系统越希望抵抗强观察者和流量相关攻击, 就越需要引入延迟、批处理、重排序、填充或覆盖流量等机制。但这些机制又会降低交互性, 增加网络负载, 并影响用户持续使用的意愿。因此, 匿名通信系统的安全性不仅取决于协议是否能够在理论模型下隐藏通信关系, 还取决于这些保护机制能否在真实网络、真实设备和真实用户行为中被长期部署。

2.3.1 匿名性与时延

Mix 网络通过延迟和重排序削弱输入输出流量之间的统计对应关系,因而更适合对抗强流量观察者,但如果延迟过高,系统就难以支持 Web 浏览、即时通信等交互式应用。Loopix、LARMix 和 LAMP 等工作正是在这一背景下尝试降低 Mix 网络的可用性成本。Loopix 通过 Poisson mixing 和覆盖流量将 Mix 网络推进到秒级延迟场景 [7], LARMix 通过延迟感知路由改善路径选择 [8], LAMP 则进一步降低大规模部署中的路由计算开销 [9]。

然而,降低延迟往往意味着系统会暴露更多可被学习的流量结构。对于 Tor 这类低延迟洋葱路由系统而言,其核心优势在于能够支持大规模、低门槛的交互式匿名访问,但为了保证可用性,Tor 不能像高延迟 Mix 网络那样充分打散端到端时序关系。因此,攻击者可以利用包方向、包长序列、突发模式和访问持续时间等特征进行网站指纹识别或流量相关分析。Shen 等人通过鲁棒流量表示绕过多种网站指纹防御 [4],Zhao 等人进一步将攻击粒度推进到细粒度网页级识别 [5],说明低延迟匿名网络在真实环境中仍然面临持续演化的流量侧信道风险。

2.3.2 流量侧信道与防御成本

针对流量侧信道,常见防御思路包括流量填充、流量整形、延迟注入和覆盖流量等。这些方法的共同目标是在不解密通信内容的情况下,削弱攻击者从流量形状中恢复访问行为或通信关系的能力。DeTorrent 通过对抗训练生成填充策略,在不延迟真实流量的前提调度 dummy packets,以降低网站指纹和流量相关攻击的有效性 [17]。Maybenot 则将流量分析防御抽象为概率状态机框架,使 padding 和 blocking 策略能够在 Tor、TLS、QUIC 和 VPN 等不同通信场景中复用 [18]。防御研究正在从单一攻击场景下的专用算法,逐渐转向更通用、可组合和工程化的防御框架。

防御机制自身也会引入新的成本和边界条件。填充和覆盖流量会增加带宽消耗,延迟注入会影响交互体验,复杂的自适应防御还可能带来实现难度和部署兼容性问题。NetShaper 从差分隐私角度对网络侧信道进行流量整形,试图用形式化隐私参数刻画包大小和时序泄露的防护强度,但其设计同样需要在隐私保证、带宽开销和延迟成本之间进行参数化配置 [19]。匿名网络防御并不存在无成本的安全增强,任何削弱流量可区分性的机制,都必须以某种资源消耗、性能损失或系统复杂度为代价。

2.3.3 真实部署与评估

可部署性还与终端设备、网络环境和用户行为密切相关。Hugenroth 等人对智能手机上匿名网络的能耗进行测量,发现 Tor 持续运行的额外能耗相对有限,而持续发送覆盖流量的 Mix 类系统则更容易受到无线链路和设备能耗约束影响 [20]。匿名网络的实际可用性不能只从服务器端吞吐量或协议延迟评估,还必须考虑移动设备、电池消耗、网络波动和用户持续在线等现实条件。对于依赖大量覆盖流量或持续连接的系统而言,这些因素可能直接决定其能否被普通用户长期采用。

匿名网络的评估也受到数据集和实验设置的影响。许多网站指纹和流量分析研究依赖受控环境下采集的合成数据,而真实用户访问行为往往具有更复杂的访问分布、会话长度、并发请求和背景流量。Jansen 等人构建真实 Tor 流量轨迹数据集,指出合成数据与真实 Tor 使用之间存在显著差异 [6]。匿名网络攻防研究不能仅以理想化准确率或封闭世界实验作为结论依据,而应进一步关注开放世界环境、基础率问题、真实流量分布和长期部署后的攻击适应性。

匿名网络的核心矛盾可以概括为越强的匿名性通常需要越高的延迟、带宽和系统复杂度,而越好的交互性和可部署性又往往会暴露更多可被流量分析利用的统计特征。Mix 网络、洋葱路由和各类流量整形机制分别代表了不同的设计折中。正是这种安全目标与现实约束之间的张力,使得 Tor 网络成为匿名通信研究中最具代表性的系统,它在真实世界中获得了广泛部署,同时也集中暴露了低延迟匿名网络在网站指纹、流量相关、洋葱服务安全和匿名化滥用治理方面的典型问题。

3 Tor 网络攻防技术

Tor (The Onion Router) 是匿名网络核心矛盾最具代表性的系统实现之一,也是当前部署规模最大、研究最充分的低时延匿名通信系统 (low-latency anonymous communication system) 之一。自第二代洋葱路由系统被提出以来,Tor 逐步形成了由客户端 (Client)、志愿者中继 (Relay)、目录基础设施 (Directory Infrastructure)、出口策略 (Exit Policy)、洋葱服务 (Onion Service, 旧称 Hidden Service)

与可插拔传输 (Pluggable Transport) 共同构成的复杂匿名通信生态 [3, 21]。从安全研究视角看, Tor 并非单一密码协议, 而是一个同时受到密码学设计、互联网路由、流量统计学习、系统资源管理与审查对抗共同影响的大规模网络系统。因此, 围绕 Tor 的攻防研究也呈现出明显的多层化特征: 攻击侧从早期的节点控制与流量关联, 发展到深度学习网站指纹、自治系统/边界网关协议级观测 (AS/BGP-level observation)、洋葱服务会话关联、带宽膨胀和目录共识破坏; 防御侧则从链路层协议加固、守卫节点策略和目录共识机制, 扩展到流量填充、路由感知路径选择、隐私保护测量、抗审查传输和面向洋葱服务的性能优化。本节按照“架构基础-攻击演进-防御对抗-态势分析”的逻辑, 对 Tor 网络攻防技术进行系统化梳理, 并为后续讨论匿名网络与僵尸网络隐匿通信之间的关系提供技术基础。

3.1 Tor 网络架构基础

Tor 的安全性建立在多跳转发、分层加密和目录基础设施之上, 但其攻击面也正是由这些系统组件共同决定的。为了支持低时延交互式通信, Tor 需要在客户端侧完成路径选择, 通过目录基础设施获取中继状态, 并依赖守卫节点、中间节点和出口节点共同转发流量。同时, 洋葱服务、可插拔传输和隐私保护测量等扩展机制又进一步扩大了 Tor 的系统边界。因此, 在分析具体攻击与防御之前, 有必要先从系统组成、核心协议流程和扩展机制三个层面梳理 Tor 的架构, 并指出各组件对应的潜在攻击面。

3.1.1 系统组成与节点角色

Tor 的思想源于一代洋葱路由 (Onion Routing)。Syverson、Goldschlag 与 Reed 提出的匿名连接模型已经奠定了“发送方构造多层加密洋葱、每个中继只剥离一层并获得下一跳”的基本范式 [22]。Dingledine 等人提出的 Tor 则在此基础上完成了面向互联网部署的系统化重构: 其核心目标不是提供绝对意义上的不可追踪性, 而是在可接受时延和带宽开销下, 使任一单点观察者难以同时获得通信双方身份 [3]。这种设计决定了 Tor 本质上属于低时延匿名系统, 适合 Web 访问、即时通信和一般 TCP 应用, 但并不承诺抵御能够同时观察全网入口与出口流量的全局被动攻击者 (Global Passive Adversary, GPA)。

Tor 网络的基础实体主要包括客户端、中继节点、目录权威服务器和目录缓存。客户端负责获取目录信息、选择路径、建立电路并将本地应用流量封装为 Tor 信元。中继节点则按照其在电路中的位置承担不同角色, 包括直接连接客户端的守卫节点、负责公网访问的出口节点, 以及用于隔离入口和出口关系的中间节点。守卫节点能够观察用户 IP 但不知道最终访问目标, 出口节点能够观察目的站点及未被端到端加密保护的应用层内容但不知道用户真实地址, 中间节点则仅知道前后两跳。目录权威服务器和目录缓存共同维护中继描述符、网络状态共识和路径选择所需的权重信息, 从而为客户端构建电路提供全网视图 [21]。

除上述基础实体外, Tor 还包含出口策略 (Exit Policy)、洋葱服务 (Onion Service) 和可插拔传输 (Pluggable Transport) 等重要机制。出口策略规定出口中继允许连接的目标端口和协议范围, 影响客户端能否为特定目标选择某个出口中继。洋葱服务允许服务端隐藏自身网络位置, 使客户端和服务端均通过 Tor 链路完成连接。可插拔传输则主要服务于抗审查场景, 通过改变 Tor 流量的外部形态来降低被深度包检测 (Deep Packet Inspection, DPI) 直接识别和封锁的概率。由此可见, Tor 基础架构并非仅由三跳中继构成, 而是由“目录发现-路径选择-链路传输-出口访问/洋葱服务-审查规避”共同组成的完整系统。

3.1.2 核心协议: 目录共识、链路构建与洋葱加密

目录共识 (Directory Consensus)。 Tor 客户端在建立通信前首先需要获得可信的网络视图。目录权威服务器周期性收集中继上传的服务器描述符 (Server Descriptor) 和微描述符, 并对中继是否在线、可达、稳定、是否适合担任守卫或出口等状态进行投票, 最终生成带有多方签名的网络状态共识 [21]。客户端下载并验证该共识后, 可以获得中继身份、公钥摘要、地址、端口、带宽权重、出口策略摘要及 Guard、Exit、Stable、Fast 等标志位。现代 Tor 客户端通常并不需要下载完整服务器描述符, 而是使用体积更小的微描述符共识和必要的微描述符, 以降低启动和更新目录信息的带宽开销。目录共识的直接功能是提供路径选择所需的全网中继名录和权重信息, 而不是在本节中展开其安全目的。目录权威和目录缓存的安全意义将在后文基础设施攻防中讨论。

链路构建 (Circuit Construction)。获得共识后,客户端按照带宽权重、角色约束、出口策略、守卫节点策略和路径选择规则,在本地选择一条通常由三跳组成的链路,即“客户端-守卫-中间-出口”。需要强调的是,客户端可以在本地规划完整路径,但协议交互并不会一次性把完整路径暴露给任一中继。Tor 采用增量式的望远镜式构建 (Telescoping Construction),客户端首先与第一跳守卫节点完成认证密钥交换并建立第一段链路,随后通过已经建立的前缀链路向第二跳发送扩展请求,最后再经由前两跳将链路扩展至第三跳出口中继 [3, 21]。在该过程中,每个中继只知道自己的前一跳和后一跳,不能单独恢复完整通信路径。链路建立完成后,多个应用层 TCP 流可以在同一链路上多路复用 (Stream Multiplexing),从而降低频繁建路带来的性能开销。

洋葱加密 (Onion Encryption)。Tor 的密码学结构可以概括为“非对称握手建立每跳密钥,对称加密承担高频数据转发”。在链路创建阶段,客户端分别与链路上的每个中继协商独立会话密钥在数据传输阶段,应用数据被切分为固定大小信元并进行多层对称加密。客户端发送方向上,数据依次使用出口、中间、守卫三跳密钥进行嵌套加密,沿路径转发时,每个中继只解开属于自己的一层并根据内部头部信息转发给下一跳。反向传输时,出口、中间、守卫依次增加加密层,客户端最终逐层解开。固定大小信元、多路复用 TCP 流和完整性校验共同降低了简单包长指纹和标签攻击风险,但并不能消除数据包方向、突发结构、时序间隔与连接持续时间等元数据泄露。因此,目录共识解决“有哪些中继可选”的问题,链路构建解决“如何逐跳建立匿名路径”的问题,洋葱加密解决“如何让单个中继只能看到局部转发信息”的问题,三者共同构成 Tor 匿名通信的核心协议基础。

3.1.3 洋葱服务、可插拔传输与真实网络测量

除访问公网服务外,Tor 还支持洋葱服务 (Onion Service)。洋葱服务允许服务端隐藏自身 IP 地址,并通过引入点 (Introduction Point) 与汇合点 (Rendezvous Point) 完成客户端和服务端的匿名连接。与普通出口链路相比,洋葱服务通常需要客户端侧三跳链路与服务端侧三跳链路共同参与,路径更长、交互轮次更多,因此在延迟、吞吐和可用性上面临更大压力。Winter 等人通过访谈、问卷和 .onion 查询数据研究发现,用户对洋葱服务的心理模型并不完整,对地址发现和站点认证机制存在明显不满,同时现实中还存在大量相似洋葱地址和钓鱼风险 [23]。这说明洋葱服务的安全问题不仅是协议问题,也包含可用性、身份认证和用户认知问题。

在审查环境中,Tor 还依赖可插拔传输 (Pluggable Transport) 隐藏或改变 Tor 流量的可识别特征。其基本思想是在客户端和桥接节点 (Bridge) 之间增加一层传输封装,使审查者难以仅凭 Tor 握手或流量格式识别 Tor 连接。Snowflake、WebRTC 封装和后续瞬时代理方案均属于这一方向。可插拔传输并不改变 Tor 内部的链路和洋葱加密语义,而是改善客户端进入 Tor 网络之前的可达性问题,因此它在系统架构中连接了匿名通信与抗审查通信两个研究脉络。

对真实 Tor 网络的理解还依赖隐私保护测量 (Privacy-Preserving Measurement)。Mani 等人基于 PrivCount 和 Private Set-Union Cardinality 对 Tor 进行测量,发现 Tor 日均用户规模可能显著高于传统估计,并观察到大量失败的洋葱地址查询 [24]。该类工作的重要意义在于,Tor 研究不能只停留在协议规范或小规模实验网络中,而必须在不伤害用户隐私的前提下理解真实流量、真实服务和真实攻击面。

总体来看,Tor 的攻击面并不局限于洋葱加密本身,而是分布在目录发现、路径选择、入口与出口观测、洋葱服务、抗审查接入和真实网络测量等多个层次。客户端侧和守卫侧流量可能被用于网站指纹识别,入口与出口两端观测可能支持端到端流量相关,目录与带宽测量机制可能被用于影响路径选择概率,而洋葱服务和可插拔传输又分别引入服务发现、会话关联和抗审查对抗等问题。

3.2 攻击技术分类与演进

Tor 攻击可以从攻击者观测位置与攻击目标两个维度进行划分。前者包括客户端侧、入口侧、出口侧、洋葱服务侧、互联网路由层以及目录/带宽测量基础设施。后者则包括识别访问网站、关联通信双方、发现或干扰洋葱服务、操纵路径选择以及破坏网络可用性。基于这两个维度,本文将现有攻击概括为四类,第一类是面向客户端访问行为识别的流量分析攻击 (Traffic Analysis),典型代表是网站指纹。第二类是面向通信双方关系恢复的去匿名化攻击 (Deanonymization Attack),包括端到端流关联、DNS 增强关联和 AS/BGP 级攻击。第三类是面向洋葱服务的发现、可用性和会话关联攻击。第四类是面向 Tor 生态基础设施的攻击,包括拒绝服务、带宽测量操纵、目录共识破坏和潜在的 Sybil 攻击

(Sybil Attack)。这种划分既对应攻击者所在的网络层次，也对应 Tor 希望保护的不同安全属性，因而能够较系统地概括近十年 Tor 攻防研究的主要脉络。

3.2.1 流量分析攻击：网站指纹识别的深度学习化

网站指纹攻击 (Website Fingerprinting, WF) 试图在不破解 Tor 加密内容的情况下，仅利用包方向、突发长度、时间间隔和连接持续时间等元数据识别用户访问的网站或页面。2018 年前后，WF 研究逐渐从手工特征工程转向深度学习。Sirinam 等人提出 Deep Fingerprinting (DF)，使用卷积神经网络直接学习 Tor 访问轨迹中的方向序列特征，在未防御流量和部分轻量级填充防御下取得了显著高于传统方法的识别效果 [25]。Rahman 等人的 Tik-Tok 进一步说明，时序信息并非噪声，而是与方向特征互补的重要信号，其方向-时序融合表示在未防御 Tor、WTF-PAD 和洋葱站点流量上均能提升识别能力 [26]。这些工作表明，固定大小信元只能削弱单包长度泄露，无法消除流量突发结构和时序模式中蕴含的站点特征。

近年研究进一步从“能否识别网站”转向“能否在更复杂场景下保持攻击有效性”。Var-CNN 引入膨胀因果卷积和残差结构以捕捉长程时序依赖，并将自动学习特征与统计特征融合，证明深度 WF 攻击在低数据场景下仍具有较强能力 [27]。Shen 等人提出鲁棒流量表示方法，通过 Traffic Aggregation Matrix 捕获 Tor trace 中更稳定的泄露特征，说明已有填充类防御仍可能保留可被学习的结构性信息 [4]。Mitseva 和 Panchenko 则指出，用户在真实浏览中往往连续访问同一网站的多个子页面，若将这些访问作为集合进行建模，网站指纹攻击的实际威胁会被进一步放大 [28]。Oscar 将问题从“识别网站”推进到“识别同一网站内部具体网页”，通过多标签度量学习处理多页面混合和细粒度网页差异，在大规模监控页与非监控页数据集上显著提升 Recall@5 [5]。

综上，流量分析攻击的演进体现出三个趋势，一是深度模型降低了攻击者对人工特征工程的依赖。二是包方向、突发结构和时序信息共同构成持续泄露源。三是研究前沿正在从封闭世界网站分类转向开放世界、细粒度网页识别、多页面行为建模和跨时间泛化。这意味着 Tor 的内容加密并不等同于元数据隐藏，低时延设计仍会保留可供统计学习利用的通信节奏。

3.2.2 去匿名化攻击：流关联、DNS 泄露与 AS 级对手

当攻击者能够同时观察客户端到守卫节点的入口侧流量和出口节点到目的站点的出口侧流量时，攻击目标便从“用户访问了哪类网站”升级为“某个用户是否正在访问某个具体目标”。DeepCorr 利用深度学习模型学习 Tor 流量在多跳转发中的噪声和扰动模式，从而对入口流和出口流进行端到端相关性判断 [29]。该工作的重要性在于，它降低了流关联攻击对精心设计统计指标的依赖，说明中等规模多点观察者也可能借助数据驱动模型提升去匿名化能力。

DNS 路径进一步扩大了流关联攻击的观测面。Greschbach 等人指出，Tor 出口节点对公共 DNS 解析器的选择存在集中化现象，攻击者若能观察出口 DNS 请求，便可将 DNS 信息与客户端侧网站指纹结合，从而显著提升关联攻击效果 [30]。Tor 的匿名性不仅取决于 Tor 覆盖网络本身，还受出口侧 DNS 解析、目的站点部署和互联网基础设施集中化影响。

更底层的威胁来自自治系统级对手 (AS-level Adversary) 和边界网关协议级对手 (BGP-level Adversary)。AS 级攻击者不需要控制 Tor 中继，只需位于客户端-守卫路径和出口-目的路径的共同自治系统上，便可能被动关联两端流量。Sun 等人系统分析主动 BGP 前缀劫持对 Tor 匿名性的影响，说明攻击者可通过路由操纵使自身出现在入口或出口路径上 [31]。Gegenhuber 等人进一步利用 RIPE Atlas 长期测量不同国家客户端、Tor 入口路径和目标 AS 之间的关系，展示了 AS 级流量关联风险的地域差异和带宽集中化效应 [32]。

由此可见，Tor 的三跳链路能够阻止单个中继同时获知通信双方，但不能消除端到端流量模式和底层互联网路径所带来的相关性。攻击者的优势不一定来自破解加密，而可能来自 DNS 解析集中化、互联网路由可见性、BGP 操纵能力或入口/出口两侧长期观测能力。这说明 Tor 的威胁模型不能仅限于覆盖网络内部的恶意节点，还需要纳入 DNS 解析、互联网路由和跨域流量观测等基础设施因素。

3.2.3 洋葱服务攻击：服务发现、用户信任与会话关联

洋葱服务因同时隐藏客户端和服务端位置，通常被认为能够提供比普通出口访问更强的服务端位置隐藏能力，但其更长路径和更复杂握手也引入了新的攻击面。Winter 等人的用户研究表明，洋葱服

务在地址发现、服务认证和用户信任方面存在天然脆弱性，攻击者可利用相似地址、过期链接和用户对 .onion 机制理解不足实施钓鱼或误导 [23]。这类问题并不直接破坏 Tor 密码协议，却会在实际使用中削弱匿名服务的安全性。

在网络层，Lopes 等人针对洋葱服务会话提出基于滑动子集和 (Sliding Subset Sum, SUMo) 的流关联攻击，面向客户端与洋葱服务之间的会话流量进行过滤、时间对齐和滑动窗口匹配 [33]。与普通出口链路相比，洋葱服务路径更长、噪声更多、可能存在链路填充和多路复用，因此过去常被认为更难关联。该工作表明，只要攻击者在合适位置获得足够观测能力，仍可能通过高效统计匹配恢复会话关联关系。

洋葱服务的攻击面具有双重性，一方面，服务发现、地址认证和用户信任问题会在应用层削弱安全性。另一方面，长路径并不自动等价于强抗关联能力，网络层攻击者仍可利用会话级流量特征进行关联。因此，洋葱服务安全不能仅依赖路径更长这一直觉，而需要将协议防护、用户可用性、服务发现、流量填充和 DoS 防御共同纳入设计。

3.2.4 基础设施攻击：资源耗尽、带宽操纵与目录共识破坏

基础设施攻击关注的不是某条链路的瞬时匿名性，而是 Tor 网络维持可用性和可信路径选择所依赖的资源管理、带宽测量与目录共识。Jansen 等人提出的狙击手攻击 (Sniper Attack) 揭示了 Tor 早期拥塞控制和传输队列设计可被用于低成本拒绝服务 (Denial of Service, DoS)，恶意客户端或服务端通过操纵读取行为和 SENDME 机制，使目标中继积累大量未释放数据，最终耗尽内存并崩溃 [34]。该攻击的意义在于，DoS 不只是可用性威胁，还可能通过选择性排除守卫或出口节点改变用户路径选择，进而服务于去匿名化。相关实验大量依赖 Shadow 仿真框架，Jansen 等人关于 Tor 网络建模的方法论也成为后续安全评估的重要工具 [35]。

2023 年以来，研究焦点进一步转向带宽测量和目录共识机制。Sendner 等人提出带宽膨胀攻击 (Bandwidth Inflation Attack)，利用多个中继共享资源以及带宽测量流量可被识别的缺陷，使攻击者控制的节点在共识中获得高于真实能力的带宽权重，从而增加被选入用户链路的概率 [36]。这类攻击直接挑战了 Tor “按带宽加权选择路径”的基础假设。Luo 等人针对目录协议提出短时 DDoS 破坏共识生成的研究，指出现有目录权威协议在网络同步假设上存在脆弱性，并提出基于部分同步模型的缓解方案 [37]。该工作揭示了 Tor 攻防正在从客户端流量层面扩展到目录、测量和共识协议本身。

基础设施攻击说明 Tor 匿名性依赖的不仅是洋葱加密和路径分离，还包括中继资源管理、带宽权威测量、目录共识可用性与中继生态健康。若攻击者能够通过 Sybil 部署、带宽膨胀或目录破坏影响路径选择概率，即使不破解任何密码原语，也可能系统性提高自身被选入用户链路的几率。

3.3 防御技术与对抗

Tor 防御技术需要同时受到匿名性、性能、部署成本和兼容性的约束。对于流量分析攻击，防御重点在于通过填充、延迟或突发整形削弱流量形状特征。对于端到端去匿名化和路由级攻击，防御重点转向守卫节点策略、路径选择和互联网路由风险感知。对于洋葱服务和基础设施攻击，防御还需要考虑服务发现、会话关联、带宽测量和目录共识鲁棒性。与高时延 Mix 网络不同，Tor 不能依赖长时间批处理、强制重排序或大量固定速率覆盖流量来完全隐藏端到端时序关系，否则会破坏 Web 浏览等交互式应用体验。因此，Tor 防御研究的核心不是寻找“零开销”的强匿名机制，而是在攻击收益、用户体验和部署复杂度之间进行权衡。

3.3.1 面向流量分析的混淆与填充防御

针对网站指纹攻击，防御思路主要包括填充 (Padding)、延迟 (Delay)、突发整形 (Burst Shaping) 和对抗扰动 (Adversarial Perturbation)。Holland 与 Hopper 提出的 RegulaTor 以下载流量速率衰减模型和上传/下载比例约束重塑网页加载轨迹，并在预算范围内注入哑包 (Dummy Packet)，从而降低 WF 分类器对突发形状的利用能力 [38]。其贡献不只在降低分类准确率，更在于强调防御评估必须同时报告带宽开销、延迟开销和开放世界效果。DeTorrent 进一步采用对抗训练生成填充策略，代表了填充型防御向对抗式、可部署方向发展的趋势 [17]。Maybenot 则将流量分析防御抽象为概率状态机，使 padding 和 blocking 策略能够在 Tor、TLS、QUIC 和 VPN 等不同场景中复用 [18]。

但是, 流量混淆存在现实上限。若防御过弱, 深度模型仍可利用剩余方向和时序模式; 若防御过强, 则会造成不可接受的带宽与延迟膨胀。更重要的是, 攻击者可以采用自适应训练, 将防御后的流量纳入训练集, 使静态规则防御迅速失效。因此, 针对 WF 的防御不能只追求封闭世界准确率下降, 而应同时关注开放世界误报率、真实网页加载性能、长期模型漂移和部署兼容性。

3.3.2 面向去匿名化的路径选择与路由防御

针对端到端流关联、DNS 泄露和 AS/BGP 级攻击, 防御重点不在于改变单个数据包内容, 而在于降低攻击者同时观察通信两端的概率。守卫节点机制 (Guard Mechanism) 通过长期固定少量入口节点, 降低用户在频繁随机选择入口时遇到恶意守卫的概率。出口策略和路径选择规则则约束出口节点的可用范围, 并避免选择不满足角色、网络位置或安全约束的路径 [21]。针对 AS/BGP 级攻击, Counter-RAPTOR 提出将 AS 弹性纳入守卫选择, 并结合 BGP 异常监测对路由劫持进行检测 [31]。这一思路说明, Tor 协议层防御不能只优化覆盖网络内部路径, 还必须考虑底层互联网路径是否会把入口侧和出口侧同时暴露给同一观察者。

DNS 相关风险的缓解则需要同时关注出口节点配置和公共解析器集中化问题。DefecTor 揭示的关键问题并不是 Tor 链路内部加密失败, 而是出口侧 DNS 解析路径为攻击者提供了额外观测信号 [30]。因此, 防御方向包括减少出口侧对集中式公共 DNS 解析器的依赖、改善出口节点解析策略、在路径选择中纳入出口侧基础设施风险, 以及通过测量识别高风险解析路径。面向去匿名化的防御应从“单条 Tor 链路是否安全”扩展为“客户端-守卫、出口-目的站点和 DNS/AS 路径整体是否暴露给同一观察者”。

3.3.3 面向洋葱服务的认证、会话防护与性能改进

针对洋葱服务攻击, 防御需要同时处理应用层可用性和网络层关联风险。应用层方面, Winter 等人的用户研究说明, 洋葱地址难以记忆、服务发现困难和钓鱼风险会削弱用户对洋葱服务的正确使用 [23]。洋葱服务防御不仅包括协议级加密, 还应包括更可靠的地址认证、可信服务发现、用户界面提示和钓鱼检测机制。网络层方面, 针对 SUMo 等会话级流关联攻击, 防御方向包括更细粒度的链路填充 (Circuit Padding)、会话级流量整形、降低多路复用带来的可分离特征, 以及在不显著增加时延的情况下扰乱客户端侧与服务端侧流量对应关系 [33]。

洋葱服务还面临突出的性能问题。DarkHorse 提出基于 UDP 的数据传输框架, 试图缓解洋葱服务中 TCP-over-TCP、长路径和多轮握手带来的高延迟问题 [39]。性能优化本身也是一种安全增强, 更低延迟和更高可用性可以减少用户绕过安全机制或转向不可信替代服务的动机。不过, UDP 带来的乱序、丢包和路径语义变化需要与 Tor 现有链路抽象、可靠性机制和匿名性假设重新协调, 因而仍需要谨慎评估其部署风险。

3.3.4 面向基础设施与抗审查的系统级防御

面对基础设施攻击, 防御重点转向资源约束、带宽测量可信性和目录共识鲁棒性。Sniper Attack 之后, Tor 需要在拥塞控制、传输队列和流控窗口上限制攻击者可放大的资源消耗 [34]。MirageFlow 揭示带宽测量机制可能受到共驻中继集群和资源共享策略操纵, 因此带宽权威测量需要更强的抗操纵能力, 避免测量流量识别、共享资源和策略性丢弃用户流量造成路径选择偏斜 [36]。目录协议方面, 部分同步模型和更稳健的投票恢复机制可增强目录权威在短时 DDoS 或网络分区下的可用性 [37]。Tor 匿名性不仅依赖密码学正确性, 还依赖测量系统、共识协议和网络资源治理的可信性。

在抗审查方面, Tor 长期依赖可插拔传输将 Tor 流量伪装成更难被识别或更高封锁代价的协议流量。MacMillan 等人对 Snowflake 的研究表明, 基于 WebRTC 的抗审查传输虽然能利用大量临时代理提高可达性, 但其握手特征和流量行为仍可能与真实 WebRTC 应用存在可区分差异 [40]。Sun 与 Shmatikov 提出的差异降级攻击 (Differential Degradation Attack) 进一步说明, 审查者不一定需要准确分类流量, 只需制造某些网络退化条件, 使规避系统性能下降而正常应用仍可接受, 即可形成低成本封锁 [41]。Vilalonga 等人的 Obscura 则代表了后续方向, 将流量封装进 WebRTC 媒体流, 结合瞬时代理和可靠传输层, 试图同时抵抗深度包检测、代理枚举和差异降级 [42]。总体来看, 抗审查研究已经从简单地“让 Tor 流量不像 Tor”, 转向提高识别、封锁和差异化降级的综合成本, 即使审查者能够观察流量, 也难以在不误伤正常应用的情况下稳定阻断 Tor 接入。

3.4 攻防态势分析

综合前述文献可以看到, Tor 攻防研究已经从早期围绕单点协议机制的安全分析, 逐渐扩展为跨越流量统计学习、互联网路由、洋葱服务、目录基础设施和抗审查系统的系统级攻防博弈。攻击者并不一定需要突破 Tor 的密码学原语, 而是可以利用低时延通信保留的元数据、真实互联网路径的可观测性、目录和带宽测量机制的脆弱性, 以及用户在服务发现和地址认证中的认知缺陷。相应地, 防御研究也不再局限于单一协议修补, 而是需要在路径选择、流量填充、路由风险感知、带宽测量、目录共识和可插拔传输等多个层面协同展开。

第一, **攻击能力从规则化特征分析走向数据驱动建模**。早期网站指纹攻击依赖人工构造的包长、方向和突发特征, 而 DF、Tik-Tok、Shen 等人的鲁棒流量表示以及 Oscar 等工作表明, 深度模型能够从加密流量的方向、时序和突发结构中自动提取稳定特征, 并将攻击目标从网站级识别推进到多页面、细粒度网页和开放世界场景 [25, 26, 4, 5]。Tor 的内容加密并不能消除元数据泄露, 防御研究也不能只依赖封闭世界准确率下降, 而应进一步关注开放世界误报率、跨时间泛化、真实浏览行为和部署开销。

第二, **去匿名化攻击面从 Tor 覆盖网络内部扩展到底层互联网基础设施**。DeepCorr 说明入口-出口流关联可以由深度模型增强 [29], DefecTor 揭示 DNS 解析路径会扩大出口侧观测面 [30], Counter-RAPTOR 和 AS 级测量研究则表明, BGP 路由、自治系统路径和中继带宽集中度都会改变用户的实际暴露风险 [31, 32]。Tor 匿名性不能仅由三跳链路结构解释, 而必须放入真实互联网路由、公共解析器、跨域流量监测和长期多点观察的环境中评估。

第三, **基础设施安全成为 Tor 生态的关键瓶颈**。Sniper Attack、MirageFlow 和目录 DDoS 研究分别指向资源管理、带宽测量和目录共识三个核心支柱 [34, 36, 37]。攻击者如果能够影响中继可用性、带宽权重或目录共识, 即使不破解任何密码原语, 也可能通过改变路径选择概率、降低网络可用性或迫使用户连接恶意中继来削弱匿名性。这一趋势对于后续僵尸网络匿名化研究尤其重要, 当 botnet 将 Tor 作为 C&C 隐匿层时, 其稳定性同样依赖 Tor 中继生态和目录基础设施。反过来, Tor 基础设施层面的异常也可能影响恶意流量隐匿与防御监测之间的平衡。

第四, **防御研究越来越强调可部署性而非单一安全指标**。RegulaTor、DeTorrent 和 Maybenot 体现了流量分析防御在带宽、时延和工程兼容性上的约束 [38, 17, 18]。Counter-RAPTOR 体现了路由安全与匿名性之间的权衡 [31]。DarkHorse 和 Obscura 则分别从洋葱服务性能和抗审查接入角度探索 Tor 系统边界 [39, 42]。Tor 的未来演进很可能不会依赖某个单一突破, 而是由路径选择、拥塞控制、流量填充、目录共识、抗审查传输和隐私保护测量等机制的协同优化共同推动。

由此可见, Tor 网络的核心矛盾始终是低时延可用性与强匿名性之间的权衡。攻击者只要在入口观测、出口观测、路由操控、流量统计、带宽测量或目录治理中的某一环节取得优势, 就可能显著削弱 Tor 对通信关系的保护能力。防御者则必须在不显著牺牲可用性和开放部署生态的前提下, 同时约束多类攻击面。这种攻防不对称性决定了 Tor 仍将是匿名通信、安全测量和网络攻防研究中的长期核心对象。与此同时, Tor 的匿名路由、洋葱服务和抗审查机制既支撑合法隐私保护, 也可能被恶意行为者用于隐藏 C&C 基础设施、规避追踪并提高僵尸网络韧性。

4 僵尸网络匿名化与检测

僵尸网络 (botnet) 本质上是一类由攻击者远程控制的大规模受感染主机集合。其危害不只体现在分布式拒绝服务攻击 (DDoS)、垃圾邮件投递、凭证窃取、勒索软件分发和加密货币挖矿等直接攻击行为上, 更体现在其背后持续演化的控制基础设施。与传统恶意软件相比, 僵尸网络的核心不在单个恶意样本, 而在于由感染节点、命令与控制 (Command and Control, C&C) 信道、更新机制、攻击载荷分发机制和收益变现链条构成的长期运营系统。匿名网络的引入改变了这一系统的攻防边界, 攻击者不再仅仅试图隐藏恶意代码本身, 而是试图隐藏控制者、控制服务器与受控节点之间的关联关系, 以及攻击基础设施在网络空间中的真实位置。因此, 僵尸网络匿名化问题应被理解作为一种跨越基础设施、通信协议、命名系统、拓扑结构和运营行为的系统性对抗问题。

本章围绕“僵尸网络如何利用匿名化机制增强生存能力, 以及防御者如何识别匿名网络中的恶意控制行为”展开。首先区分匿名化、隐蔽化和抗接管等相关概念, 并分析僵尸网络控制架构从中心化 C&C 到 P2P、混合式和匿名化后端的演进动机, 随后总结 Tor 被僵尸网络利用的主要模式与典型案例, 接着讨论 Tor 环境下僵尸网络检测面临的特殊挑战, 最后从流量特征、主机侧关联、时序建模、图学习、DGA 检测、联邦学习和去匿名化边界等角度归纳现有检测与治理方法。

4.1 概念界定与匿名化动机

4.1.1 匿名化、隐蔽化与抗接管

在讨论僵尸网络匿名化之前，有必要区分三个容易混淆但安全目标不同的概念：匿名化、隐蔽化以及抗封堵/抗接管。三者在现实僵尸网络中经常组合出现，但对应的防御含义并不相同。

匿名化 (anonymization) 强调隐藏通信实体的身份、位置和关联关系。对于僵尸网络而言，匿名化的直接目标包括隐藏控制者真实身份、隐藏 C&C 服务器真实 IP、隐藏 bot 与控制端之间的网络路径，以及阻断防御者从恶意活动回溯到攻击基础设施的能力。Tor 洋葱服务、I2P、匿名代理链、混合网络 (Mix Network) 以及利用隐私型区块链或 Lightning Network 构造的命令通道均属于这一层面的技术。匿名化的关键问题不是“通信内容是否可读”，而是“通信双方及其位置是否可被识别”。

隐蔽化 (covert communication 或 traffic hiding) 强调隐藏通信内容、通信意图或流量模式，使 C&C 流量在观测上接近正常流量。TLS 1.3 加密 C&C、domain fronting、HTTPS beaconing、DNS 隧道、云服务滥用、社交媒体 C&C、流量填充和协议伪装等技术均可归入这一层面。隐蔽化并不必然提供强匿名性：例如攻击者使用普通 HTTPS 与公网服务器通信时，通信内容可能被加密，但服务器 IP 仍可能暴露；反之，Tor 洋葱服务能够隐藏服务器位置，但 Tor 流量形态本身仍可能被识别。

抗封堵与抗接管 (resilience against takedown and sinkholing) 强调提高控制基础设施在被封禁、接管或 sinkhole 时的恢复能力。典型技术包括 DGA/domain flux、fast flux、P2P 拓扑、多 C&C 轮换、备用通道、区块链域名系统和多层代理。其目标不是单纯隐藏通信实体，而是在防御者摧毁一部分基础设施后仍能维持命令传播和节点控制。

这三个层次共同构成僵尸网络匿名化生态。一个现代 botnet 可以使用 Tor 洋葱服务隐藏 C&C 位置，使用 TLS 1.3 或 domain fronting 混淆通信意图，再使用 DGA 或 P2P 机制提升控制链弹性。所以僵尸网络匿名化不能被狭义理解为“使用 Tor”，而应被理解为围绕“身份隐藏、行为伪装和基础设施生存”展开的一组组合策略。

4.1.2 控制架构演进与匿名化动机

僵尸网络控制架构大体经历了从中心化 C&C、分布式 P2P 到混合式匿名化架构的演进。早期 IRC/HTTP botnet 多采用中心化 C&C，bot 周期性连接固定服务器或频道接收命令。这种架构部署简单、命令传播延迟低、易于管理，但单点失效风险极高，一旦 C&C 域名、IP 或服务器被定位，防御者即可通过封禁、sinkhole 或执法扣押切断控制链。

为对抗中心化架构的脆弱性，P2P botnet 通过节点之间的邻居发现和命令扩散降低单点依赖。P2P 架构提高了生存能力，却也引入新的可观侧面，拓扑结构、邻居选择、消息传播周期和节点角色差异都可能被防御者建模。混合式架构则试图折中中心化和 P2P 架构的优缺点，攻击者将传播、扫描、攻击和收益变现等高频行为放在公网或普通云基础设施中，将关键控制、配置更新、备用 C&C 和身份隐藏部分放入 Tor、I2P 或其他匿名网络中。这种方式兼顾可用性和隐匿性，已经成为匿名化僵尸网络的重要趋势。

从攻击者视角看，使用匿名网络至少具有三类动机。第一是隐藏 C&C 服务器位置，Tor 洋葱服务允许服务器无需暴露公网 IP 即可被客户端访问，防御者即使获得 onion 地址，也难以直接定位服务器所在主机。第二是提高执法与封堵成本，传统 takedown 依赖域名注册商、托管商和上游网络协作，而 onion 服务的基础设施位置被隐藏，封堵往往只能转向客户端检测、入口流量识别或样本反分析。第三是利用合法匿名流量提供掩护，Tor 具有广泛的合法用途，防御者很难仅凭“使用 Tor”就采取强封堵策略，这种合法性背景为恶意流量提供了混入匿名通信生态的机会。

然而，匿名化并不意味着攻击基础设施暴露面的完全消失，而是将暴露面从 IP 地址、域名、端口和明文载荷转移到流量形态、时序规律、主机行为、拓扑结构和运维失误等侧信道之上 [43]。所以 Tor 并未让僵尸网络不可见，而是改变了防御者可利用的观测维度。检测方法也相应从传统的签名匹配、域名黑名单和内容检测，转向流量统计、长时序建模、主机侧关联、样本逆向、图结构学习和跨组织协同分析。

4.2 僵尸网络利用 Tor 的模式与真实案例

Tor 被僵尸网络利用的方式并不单一。根据 Tor 在控制链中承担的功能，可以将其划分为四类模式：基于洋葱服务的核心 CC、作为备用控制通道、作为数据外传和管理面板的隐藏层，以及作为扫描、

投递或支付环节的辅助匿名层。

4.2.1 基于洋葱服务的核心 C&C

最直接的模式是将 C&C 服务器部署为 Tor 洋葱服务，bot 在本地启动或调用 Tor 客户端，经 SOCKS 代理连接硬编码的 .onion 地址。Skynet 是早期典型案例之一，其控制逻辑基于 IRC，但 IRC 服务器隐藏于 Tor 洋葱服务之后，样本通过本地 Tor 代理进入匿名网络 [44]。这一模式保留了传统集中式 C&C 的管理便利性，同时避免暴露服务器公网地址，体现了 Tor 对中心化控制架构的“位置隐藏”价值。

ChewBacca 则展示了 Tor 与数据窃取型 botnet 的结合。该恶意软件内置 Tor 客户端，并将键盘记录、内存抓取等敏感数据上传至隐藏在 onion 地址之后的服务器 [45]。与 Skynet 相比，ChewBacca 的重点不在命令传播效率，而在于隐藏数据回传目的地，使受害组织即使发现外连 Tor 流量，也难以直接定位接收端。这说明 Tor-based C&C 不仅可用于命令下发，也可用于保护窃取数据的收集基础设施。

基于洋葱服务的 C&C 具有明显优势，C&C 服务器不需要暴露 IP，域名封禁和托管商投诉难以奏效，botmaster 可以在不更换服务器的情况下更换访问入口。然而，该模式也存在可观测弱点，样本中往往需要包含 onion 地址、Tor 客户端路径或代理配置，这些信息可能被逆向分析提取。同时，Tor 流量本身在企业网络中较为异常，若结合主机进程、SOCKS 连接、周期性通信和样本行为，仍可能形成可操作告警。

4.2.2 Tor 作为备用或混合式控制通道

攻击者很少长期将全部通信压入 Tor，因为 Tor 的延迟、带宽和可检测性会降低攻击效率。因此，现实 botnet 更常采用混合模式，公网 HTTP/HTTPS 通道负责常规心跳、更新和低敏感通信，Tor 则作为备用 C&C、配置更新或高价值命令通道。Sefnit/Mevade 是这一模式的重要历史案例。其变种曾通过 HTTP、HTTP over Tor 以及 SSH 与服务器联络，并在受害主机上安装 Tor 组件以隐藏部分通信目的地。Tor Metrics 曾记录到该时期 Tor relay 用户数从约 80 万激增至超过 500 万，这一异常增长被广泛认为与 Mevade/Sefnit 的传播有关 [46]。

混合式控制的优势在于降低单一匿名网络特征带来的暴露风险。攻击者可以把高频、低敏感的通信放在普通 HTTPS 中，而把关键配置、备用地址、凭证回传或手工控制放入 Tor。对于防御者而言，这意味着不能仅检测 Tor 流量，也不能仅检测公网 C&C，而必须将二者放入同一主机时间线中进行关联，例如某主机是否在感染后启动 Tor 进程，是否创建异常 SOCKS 代理连接，是否在短时间内访问公网下载器、异常域名和 onion 相关配置，是否伴随横向扫描、暴力破解或凭证窃取等行为。

4.2.3 Tor 作为数据外传与管理面板隐藏层

除命令控制外，Tor 还可用于隐藏数据外传接收端和后台管理面板。对信息窃取型 botnet 而言，攻击者关注的不仅是发出命令，还包括稳定收集凭证、Cookie、键盘记录、支付信息和企业内部文档。将回传服务器或管理面板部署为 onion 服务，可以减少目的服务器被追踪、封禁或接管的风险。相比普通公网数据外传，Tor 外传在网络边界中可能只表现为加密连接和固定大小包序列，载荷内容不可见，目的服务器不可见，传统 DLP、域名黑名单和托管商投诉难以直接发挥作用。

但这种模式并非不可检测。主机侧遥测可以捕捉恶意进程调用 Tor、创建本地 SOCKS 端口、访问异常文件路径或周期性读取敏感浏览器数据。网络侧可以捕捉 Tor 连接建立后的长连接、固定间隔上传、连接切片和流量突发。组织侧还可以将 Tor 使用与敏感主机角色关联，例如普通办公终端突然出现 Tor 上传行为，其风险显著高于研究人员或安全测试环境中的 Tor 使用。也就是说 Tor 虽然隐藏了目的端位置，但没有消除主机侧行为和时间序列信号。

4.2.4 Tor 作为辅助匿名层：扫描、投递与支付

Tor 有时并不承担核心 C&C，而只是作为攻击链某一环节的辅助匿名层。例如，攻击者可能通过 Tor 隐藏扫描源、隐藏恶意载荷下载源、保护后台管理面板，或在支付、勒索谈判和泄露站点托管环节使用 onion 服务。需要注意的是，这类案例不应与 Skynet、ChewBacca、Sefnit 等强依赖 Tor 的 C&C

模式混为一谈。BrickerBot 等 IoT 破坏性恶意活动显示, 攻击者可能借助匿名化基础设施隐藏扫描与投递来源, 但其与基于 onion service 的核心控制链不同 [47]。

近年的 IoT botnet 也呈现出 Tor 与传统 botnet 组件结合的趋势。EnemyBot 主要源自 Gafgyt 并吸收 Mirai 模块, 同时被报道连接到隐藏在 Tor 网络中的 C&C 服务器 [48]。在资源受限的 IoT 环境中, 攻击者未必在每个 bot 上完整运行复杂匿名通信, 而是可能通过分层代理、loader、管理端或少数中继节点接入匿名网络, 从而在性能和隐匿性之间折中。

综上, Tor 在僵尸网络中的作用并不局限于“隐藏 C&C 服务器”这一单一模式, 而是可以嵌入控制、备用通信、数据外传、管理面板、投递和支付等多个环节。对防御者而言, 关键不是简单判断某条流量是否属于 Tor, 而是判断 Tor 使用在攻击链中的功能位置, 它是核心控制信道、备用通道、数据回传层, 还是仅用于某个辅助匿名化环节, 不同功能位置对应不同检测证据和干预策略。

4.3 Tor 环境下僵尸网络检测的特殊挑战

Tor 环境下的僵尸网络检测之所以困难, 并不是因为 Tor 使所有安全信号完全消失, 而是因为传统安全监测中最依赖的地址、域名、载荷和连接关系等信号被削弱或转移。与普通公网 C&C 相比, 基于 Tor 的匿名化控制链会将可观测性从目的服务器位置和明文协议字段, 转移到主机行为、流量节律、连接上下文和跨源关联之上。因此, 防御者面对的核心问题不是“是否能够识别 Tor 流量”, 而是“如何判断某一匿名通信行为是否属于恶意控制链的一部分”。

第一, **目的地址和域名信号失效**。在普通 C&C 检测中, 目的 IP、域名注册信息、WHOIS、自治系统、证书主体和托管商历史记录都是重要特征。Tor 洋葱服务隐藏服务器位置, 网络边界通常只能看到客户端连接 Tor 中继, 而无法看到最终的洋葱服务。即使样本中存在 onion 地址, 该地址也很难像普通域名一样通过注册商封禁或托管商投诉直接处置。这使得传统基于地址信誉、域名黑名单和托管关系分析的检测方法效果显著下降。

第二, **通信内容和协议语义难以利用**。Tor 通信本身经过多层加密, 若应用层再叠加 TLS 或自定义加密, 网络侧内容检测几乎不可行。传统入侵检测系统依赖的字符串、协议字段、命令格式和恶意载荷签名很难直接使用。对于防御者而言, 可用证据更多来自连接建立过程、包方向、会话长度、周期性、主机进程和文件行为, 而不是通信内容本身。

第三, **良恶性边界更加模糊**。Tor 具有合法隐私用途, 研究人员、新闻工作者、受审查地区用户、安全测试人员和普通隐私用户都可能使用 Tor。因此, 检测系统不能简单地把 Tor 流量作为恶意指标, 否则会产生严重误报和伦理问题。真正困难的是从“匿名网络使用”进一步识别“匿名网络中的恶意控制”。

第四, **攻击者可以低成本改变行为特征**。如果检测器依赖连接持续时间、包数、上下行比例、周期性或连接间隔等统计特征, 攻击者可以通过会话切片、随机延迟、填充包、连接复用、降低心跳频率或切换备用通道改变统计分布。这类规避并不需要突破加密协议, 也不需要破坏 Tor 本身, 只需调整通信节律即可削弱检测模型的稳定性。因此, 匿名化僵尸网络检测必须考虑对抗适应, 而不能只在静态数据集上报告高准确率。

第五, **数据集与真实部署环境之间存在差距**。许多公开 botnet 数据集年代较早, 背景流量规模有限, 恶意家族覆盖不完整, 且难以反映现代 TLS、Tor 混淆、云服务 C&C、IoT botnet 和混合式控制链的复杂性。若模型只在单一数据集或受控实验环境中取得较高准确率, 并不能说明其能够在企业网、校园网、运营商网络或 IoT 边缘网关中稳定部署。真实环境中的低基率、标签缺失、流量漂移、用户行为差异和对抗规避, 都会显著影响检测效果。

4.4 匿名化 C&C 的检测技术路线

面对匿名化僵尸网络, 防御者逐渐形成了多层检测体系: 网络侧流量识别负责发现匿名/混淆信道, 主机侧遥测负责确认恶意进程和行为链, 拓扑与时序分析负责发现控制模式, 样本逆向负责提取 onion 地址和协议细节, 联邦学习和跨组织协同则试图在不集中共享原始流量的条件下提升检测覆盖面。

4.4.1 流量特征与 Tor 指纹检测

流量指纹检测主要利用连接建立阶段的包长、方向、间隔、突发模式和统计分布识别 Tor、obfs4、meek、snowflake 等匿名或混淆流量。此类方法的优势是不依赖 payload, 适合加密环境; 缺点是容易

受到网络环境、Tor 版本、混淆插件、背景流量和攻击者行为整形影响。

TPOTI 等近期工作表明,即使在 obfuscated Tor 条件下,连接早期包序列仍可能保留可识别特征,前若干个包即可提供较强分类信号 [49]。这一发现对于企业检测具有现实意义:防御者不必等待完整会话结束,也不需要解密内容,即可在连接初期对匿名流量进行风险评分。然而,必须避免将“Tor 指纹识别”等同于“Tor 僵尸网络检测”。Tor 指纹只能证明某条流量可能属于 Tor 或其混淆变体,不能证明其背后一定是 botnet。要降低误报,必须进一步结合主机进程、连接周期、外部威胁情报和攻击链上下文。

4.4.2 主机侧关联与行为链检测

主机侧遥测是区分合法 Tor 使用和恶意 Tor 使用的关键。合法用户通常主动安装 Tor Browser,进程路径、用户交互、窗口行为和访问时间具有一定规律;恶意 bot 则可能静默释放 Tor 客户端、隐藏运行进程、创建本地 SOCKS 代理、修改启动项、周期性访问 onion C&C,并伴随扫描、凭证窃取或恶意载荷下载。

Dodia 等的工作将检测特征划分为连接级与主机级两层,在数据集和企业 Zeek 日志回放中展示了主机级上下文的重要性 [50]。其启示不在于某个具体准确率,而在于检测思路的转变:网络边界看不到 onion 服务并不意味着无法检测,防御者可以将 Tor 连接与同一主机上的 DNS、HTTP、SMB、扫描行为、进程树和告警时间线关联起来,形成复合证据。对于企业环境而言,这种关联比单条 Tor 流量告警更有可操作性。

4.4.3 周期性检测与长时序建模

许多 botnet 为维持控制关系,会周期性向 C&C 发送心跳、拉取配置或上报状态。因此,周期性检测是 C2 识别的重要路线。Oškera 等 2025 年基于 Lomb-Scargle 周期图检测多流周期性,在 CTU-13 和 CESNET-CC25 数据集上报告了很高的 precision [51]。这类方法的价值在于能够在 payload 不可见、目的地址不可用的情况下,从时间结构中发现控制关系。

但周期性检测也存在明显局限。首先,现代 botnet 可以使用低频、随机抖动或事件触发式通信规避固定周期模型。其次,真实企业网络中大量正常软件也存在周期性连接,例如更新程序、云同步、遥测服务和即时通信客户端。第三,短时间窗口难以捕捉长周期 beacon,长时间窗口又会增加存储和计算成本。因此,周期性检测更适合作为高置信信号,与主机行为、目标信誉、拓扑关系和家族特征结合使用,而不宜作为单一判据。

4.4.4 图学习与 P2P/混合架构检测

当僵尸网络转向 P2P 或混合式拓扑后,单条流量特征往往不足以揭示控制结构。图学习方法将主机、连接、域名、IP 或会话表示为图中的节点和边,通过邻接关系、社区结构、消息传播模式和节点角色识别 botnet。PeerG 使用 LINE 表示学习和图对比学习提取 P2P 流交互特征,在多个数据集上评估多类 P2P 僵尸网络 [52]。B-CAT 则从顺序流量挖掘入手,区分 sporadic、periodic 和 simultaneous 三类攻击行为 [53]。

图学习方法的优势在于能够捕捉分布式控制关系,适合检测 P2P botnet、分层代理和混合式 Tor 后端。但其部署条件较苛刻:若防御者只能观测单个企业网段,可能无法看到完整 P2P 图;若 NAT、CDN、移动网络和云代理广泛存在,图结构会被压缩或扭曲;若攻击者有意插入正常流量、改变邻居选择或降低传播频率,图特征也可能发生漂移。因此,图学习更适合作为中大型网络、运营商或跨组织协同检测的组成部分。

4.4.5 DGA 与命名层动态化检测

DGA 并不直接提供匿名性,但它显著增强了 C&C 的抗封堵能力。攻击者通过算法生成大量候选域名,bot 与 botmaster 只需在特定时间窗口注册少量域名即可恢复控制。对于 Tor-based botnet, DGA 可作为 onion 地址失效或 Tor 通道受阻后的 fallback 机制,也可用于普通公网 C2 与匿名后端之间的桥接。

2024 年 RAID 的 *Down to earth!* 对 DGA 检测研究进行了系统性元评估,复现多类模型并在大量 DGA 家族上重新 benchmark,指出样本稀缺、时间漂移、家族不平衡和部署性能成本会显著削弱模型

实用性 [54]。同年 AsiaCCS 的研究进一步表明, 白盒对抗攻击可使未加固 DGA 分类器出现接近完全失效, 但对抗训练能够显著提高鲁棒性 [55]。这些发现对匿名化 botnet 研究具有直接启示: 在高度对抗环境中, 检测器不能只报告静态准确率, 还必须报告跨家族、跨时间和对抗扰动下的稳定性。

4.4.6 TLS 1.3、Domain Fronting 与高信誉基础设施滥用检测

随着 Tor 流量在部分网络中被重点监测, 攻击者也可能转向更具“正常性”的高信誉基础设施, 如 CDN、云存储、协作平台和加密 Web 服务。Domain fronting 通过连接高信誉前置域名, 将真实目标隐藏在加密 HTTP 语义中; TLS 1.3 则进一步减少握手阶段可见信息, 使证书和应用层语义更难被边界设备直接利用。

DomEye 通过流级吞吐波动识别 domain fronting 工具的异常行为, 对 meek、moat、snowflake 等工具进行了评估 [56]。Barradas 等提出证书尺寸推断和应用行为序列提取机制, 以应对 TLS 1.3 C2 场景 [57]。这类研究说明, 即便加密协议隐藏了内容, 连接行为、对象大小、请求节律和应用序列仍可能形成侧信道。但其结论必须谨慎解释: 在实验环境或特定工具集上取得较高识别率, 并不意味着对所有 TLS 1.3 C2 或所有 CDN 环境均具有稳定泛化能力。真实部署中还需要考虑 CDN 策略变化、应用版本更新、网络拥塞、用户行为差异和攻击者主动模仿正常客户端的能力。

4.4.7 联邦学习与隐私保护协同检测

匿名化 botnet 检测往往需要跨组织数据: 单个企业可能只看到少量 bot 节点, 运营商可能看到流量但缺少主机上下文, 安全厂商可能拥有样本但缺少长期网络遥测。集中共享原始流量会带来隐私和合规风险, 因此联邦学习成为近年重要方向。HTA-BotDef 等工作尝试在不共享原始数据的前提下进行 IoT botnet 协同检测 [58]。

联邦学习的意义不应只理解为“提高准确率”, 而应理解为一种治理机制: 它允许多个组织在保留本地数据控制权的情况下共享模型更新, 从而缓解匿名化 botnet 检测所需的跨域可见性问题。但该路线同样存在挑战, 包括 non-IID 数据导致模型偏移, 恶意参与方进行模型投毒, 梯度更新泄露隐私, 通信开销过大, 以及不同组织的标签标准不一致。因而, 联邦学习更适合作为未来跨组织协同检测的框架, 而非已经成熟解决所有问题的技术。

4.5 攻防态势分析

4.5.1 攻击者策略与防御者响应

表 1 对攻击者匿名化/隐蔽化机制与防御者检测思路进行对应。与上一节不同, 该表强调攻击者技术、目标、Tor 主线关系以及检测局限之间的联系。

从表中可以看出, 匿名化僵尸网络的检测不可能依靠单一技术完成。Tor 流量指纹能够回答“是否可能使用 Tor”, 主机侧遥测能够回答“该 Tor 使用是否与恶意进程相关”, 周期性检测能够回答“是否存在控制心跳”, 图学习能够回答“是否存在分布式控制结构”, DGA 检测能够回答“是否存在动态命名机制”, 而法证分析和主动测量才可能回答“是否能够定位控制者或基础设施”。这些问题处在不同层次, 不能相互替代。

4.5.2 可解释归因与对抗鲁棒性

近年来, 匿名化 botnet 检测研究正在从“能否分类”转向“能否解释、能否归因、能否对抗适应”。这是一种重要转变, 因为真实防御场景中, 检测结果不仅要给出二分类标签, 还要支持告警排序、事件调查、家族识别、封堵决策和法律取证。

LaMP 将 Tor 恶意流量检测从二分类提升到多标签家族识别, 尝试区分 downloader、ransomware、miner、backdoor 等不同恶意功能, 并利用可解释性方法分析关键特征 [59]。这类工作的重要意义在于: 对于防御者而言, “Tor 恶意流量”这个标签过于粗糙, 难以指导响应优先级; 如果能够进一步判断其属于勒索软件、矿工、后门还是下载器, 响应策略将完全不同。

但可解释性并不等于鲁棒性。LaMP 的扰动实验表明, 缩短连接持续时间、减少每连接包数、切分数据为更短连接等简单行为调整, 就可能误导部分分类器 [59]。这说明未来攻防焦点并非单纯的“加密

表 1: 僵尸网络匿名化/隐蔽化机制与检测方法对应关系

层次	攻击者技术	主要目标	与 Tor 主线的关系	检测思路	主要局限
基础设施层	Tor 洋葱服务、I2P、Lightning Network	隐藏 C&C 位置与 botmaster 身份	Tor 是最典型的隐藏 C&C 载体	样本逆向提取 onion、Tor 流量识别、主机侧关联、主动测量	容易误伤合法匿名用户;去匿名化成本高
传输层	TLS 1.3、domain fronting、HTTPS bea- coning	隐藏通信内容与真实目的地	常作为 Tor 之外的混合 C2 或 fallback 通道	证书/对象大小侧信道、吞吐波动、连接序列建模	泛化受工具、CDN、网络环境影响
命名层	DGA、domain flux、fast flux	动态化 C&C 端点, 抵抗封堵	可作为 onion 失效后的备用发现机制	DGA 分类、DNS 行为分析、时间序列检测	家族漂移、对抗样本、注册成本变化
拓扑层	P2P、hybrid、分层代理	降低单点失效, 隐藏控制路径	减少对单一 Tor hidden service 的依赖	图学习、社区发现、邻接关系建模	依赖全局视角;局部网络易漏检
行为层	低频 bea- coning、随机延迟、会话切片	规避统计特征和周期性检测	可用于 Tor 与非 Tor C2 的共同规避	长时序建模、周期性检测、异常行为关联	召回率受低频和事件触发影响
治理层	跨组织协同、隐私保护检测	在不集中原始数据下提升覆盖面	用于缓解 Tor 合法用途与恶意滥用之间的识别难题	联邦学习、分层风险评分、最小化监测	non-IID、模型投毒、合规差异

对抗解密”，而是“行为整形对抗流量指纹”。攻击者无需破解检测模型，也无需改变 Tor 协议，只需改变通信节奏、会话粒度和包序列分布，就可能使模型特征失效。

DGA 方向的研究进一步强化了这一判断。Drichel 等证明，多种白盒对抗攻击可使未加固 DGA 分类器出现严重漏报，但对抗训练可显著提高模型鲁棒性 [55]。Cebere 等则指出，许多 DGA 检测工作在数据划分、家族覆盖、时间漂移和性能成本上存在脆弱假设 [54]。这些发现共同说明，匿名化 botnet 检测评价体系至少应包含五类指标：静态准确率、跨数据集泛化能力、跨时间稳定性、对抗扰动鲁棒性和部署成本。若缺少后四项，仅凭高准确率很难说明模型具有现实价值。

4.5.3 隐私保护与去匿名化边界

僵尸网络匿名化检测必须面对一个根本矛盾：匿名网络既可能被 botmaster 滥用，也保护了新闻工作者、政治活动者、受审查地区用户、安全研究人员和普通隐私用户的合法权益。因此，防御者不能把“使用 Tor”作为封禁和取证的充分条件。更合理的原则是：仅当匿名网络使用同时伴随恶意进程、异常周期性、已知样本行为、可疑数据外传、DGA 查询、横向扫描或威胁情报命中等多重证据时，才逐步提升响应强度。

从工程上看，可以采用分层风险评分机制。第一层是匿名/混淆流量识别，用于发现 Tor、obfs4、meek、snowflake、domain fronting 或可疑 TLS C2。第二层是主机与行为关联，将匿名连接与进程树、文件修改、启动项、端口监听、DNS 请求和横向行为关联。第三层是家族识别和基础设施分析，结合样本逆向、onion 地址提取、DGA 预测、P2P 拓扑和威胁情报进行归因。第四层才是干预动作，包括阻断、隔离、sinkhole、取证和执法协作。这样的分层机制能够避免把合法匿名通信直接等同于恶意通信。

去匿名化更应被视为例外化、证据驱动和高门槛的手段。2024 年 PoPETS 的研究从法证角度指出，现实中的去匿名化成功往往依赖运营失误、跨平台标识复用、服务器配置错误、支付链条暴露和执法协作，而非单一协议层攻击 [60]。这说明防御者在学术和工程上都应谨慎看待“去匿名化”概念：协议攻击并不是唯一也不一定是最有效路径，更多现实案例来自多源证据的长期积累。

隐私保护检测技术为缓解这一矛盾提供了方向。联邦学习、差分隐私、加密遥测和本地化特征提

取都试图在减少原始数据共享的前提下提升协同检测能力。HTA-BotDef 等工作展示了联邦学习在 IoT botnet 检测中的潜力 [58]。但未来研究需要进一步回答：模型更新是否泄露组织流量特征？恶意参与方是否可以通过投毒降低检测能力？不同组织标签标准不一致时模型如何收敛？在跨境数据合规约束下如何部署？这些问题决定了隐私保护检测能否从实验室走向实际安全运营。

5 讨论

尽管近年匿名化僵尸网络检测研究取得了大量进展，仍存在若干基础性开放问题。

第一，缺少覆盖现代匿名化 C2 的统一基准。CTU-13 等传统数据集仍被大量使用，但其年代、流量背景、家族覆盖和协议环境已经难以代表现代 botnet。CESNET-CC25 等新数据集是重要补充，但仍主要覆盖部分 IoT 家族和特定场景 [51]。未来需要构建同时包含 Tor hidden service、obfs4/meek/snowflake、TLS 1.3 C2、domain fronting、DGA fallback、P2P hybrid 和 IoT botnet 的统一基准，并明确训练/测试时间划分、家族划分和背景流量来源。

第二，检测评价需要从高准确率转向可部署性。许多论文报告 99% 以上准确率，但真实网络中的误报成本、标签缺失、流量漂移和对抗适应会显著降低效果。未来评测应强制报告跨数据集泛化、跨时间泛化、低基率场景下的误报数、检测延迟、资源消耗和对抗扰动表现。对于企业安全运营而言，百万级正常连接中的 0.1% 误报也可能带来不可承受的告警量。

第三，需要区分“匿名流量检测”和“匿名恶意控制检测”。现有研究中，一部分工作解决的是 Tor/匿名流量识别，另一部分工作解决的是 botnet C2 检测，但二者之间仍有明显鸿沟 [61, 49]。未来更有价值的任务不是判断某连接是否为 Tor，而是判断某主机的匿名通信是否构成恶意控制链的一部分，并进一步识别其家族、功能和风险等级。

第四，攻防对抗需要纳入 attacker budget。未来研究应明确攻击者可以做哪些改动：是否可以改变包长、插入填充、随机延迟、切分会话、切换 Tor 插件、迁移到 TLS/domain fronting、使用 P2P fallback 或 DGA fallback。没有攻击者预算假设的鲁棒性评估，很难说明模型在真实对抗中的意义。

第五，从检测到干预的闭环仍不完整。检测模型给出恶意概率只是第一步。真正的防御目标是打断控制链、降低感染规模、保护合法用户并为取证提供证据。未来研究需要连接检测、归因、sinkholing、封堵、样本分析、基础设施接管和法律协作，形成从技术告警到行动响应的完整闭环。

第六，匿名网络治理需要跨学科视角。对 Tor-based botnet 的应对不能只依赖技术检测，还涉及平台治理、执法协作、隐私权保护、企业安全策略和国际法问题。过度封禁 Tor 可能损害合法匿名通信，过度克制又可能放任恶意基础设施。未来研究需要将安全工程、网络测量、隐私法、伦理审查和公共政策结合起来，建立可审计、可解释、比例适当的治理框架。

6 结论

在此撰写结论。

参考文献

- [1] S. Sasy and I. Goldberg, “Sok: Metadata-protecting communication systems,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [2] D. L. Chaum, “Untraceable electronic mail, return addresses, and digital pseudonyms,” *Communications of the ACM*, vol. 24, no. 2, pp. 84–90, 1981.
- [3] R. Dingledine, N. Mathewson, and P. Syverson, “Tor: The second-generation onion router,” 2004.
- [4] M. Shen, K. Ji, Z. Gao, Q. Li, L. Zhu, and K. Xu, “Subverting website fingerprinting defenses with robust traffic representation,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 607–624.
- [5] X. Zhao, X. Deng, Q. Li, Y. Liu, Z. Liu, K. Sun, and K. Xu, “Towards fine-grained webpage fingerprinting at scale,” in *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*, 2024, pp. 423–436.

- [6] R. Jansen, R. Wails, and A. Johnson, “A measurement of genuine tor traces for realistic website fingerprinting,” in *International Conference on Passive and Active Network Measurement*. Springer, 2026, pp. 277–293.
- [7] A. M. Piotrowska, J. Hayes, T. Elahi, S. Meiser, and G. Danezis, “The loopix anonymity system,” in *26th usenix security symposium (usenix security 17)*, 2017, pp. 1199–1216.
- [8] M. Rahimi, P. K. Sharma, and C. Diaz, “Larmix: Latency-aware routing in mix networks.” in *NDSS*, 2024.
- [9] Rahimi, Mahdi and Sharma, Piyush Kumar and Diaz, Claudia, “Lamp: Lightweight approaches for latency minimization in mixnets with practical deployment considerations.” in *NDSS*, 2025.
- [10] I. BEN GUIRAT, D. Das, and C. Diaz, “Blending different latency traffic with beta mixing,” *Proceedings on Privacy Enhancing Technologies*, vol. 2024, no. 2, pp. 464–478, 2024.
- [11] L. Oldenburg, M. Juarez, E. A. Rúa, and C. Diaz, “Mixmatch: Flow matching for mixnet traffic,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [12] P. Scherer, C. Weis, and T. Strufe, “Provable security for the onion routing and mix network packet format sphinx,” *arXiv preprint arXiv:2312.08028*, 2023.
- [13] Scherer, Philip and Weis, Christiane and Strufe, Thorsten, “A framework for provably secure onion routing against a global adversary,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [14] D. Chaum, “The dining cryptographers problem: Unconditional sender and recipient untraceability,” *Journal of cryptology*, vol. 1, no. 1, pp. 65–75, 1988.
- [15] C. Kocaogullar, D. Hugenroth, M. Kleppmann, and A. R. Beresford, “Pudding: Private user discovery in anonymity networks,” in *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2024, pp. 3203–3220.
- [16] W. Dong, P. Jiang, H. Duan, C. Wang, L. Zhao, and Q. Wang, “Ring of gyges: Accountable anonymous broadcast via secret-shared shuffle.” in *NDSS*, 2025.
- [17] J. K. Holland, J. Carpenter, S. E. Oh, and N. Hopper, “Detorrent: An adversarial padding-only traffic analysis defense,” *arXiv preprint arXiv:2302.02012*, 2023.
- [18] T. Pulls and E. Witwer, “Maybenot: A framework for traffic analysis defenses,” in *Proceedings of the 22nd Workshop on Privacy in the Electronic Society*, 2023, pp. 75–89.
- [19] A. Sabzi, R. Vora, S. Goswami, M. Seltzer, M. Lécuyer, and A. Mehta, “{NetShaper}: A differentially private network {Side-Channel} mitigation system,” in *33rd USENIX Security Symposium (USENIX Security 24)*, 2024, pp. 3385–3402.
- [20] D. Hugenroth and A. R. Beresford, “Powering privacy: On the energy demand and feasibility of anonymity networks on smartphones,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 5431–5448.
- [21] The Tor Project, “Tor specifications,” <https://spec.torproject.org/index.html>, online; accessed 2026-05-28.
- [22] P. F. Syverson, D. M. Goldschlag, and M. G. Reed, “Anonymous connections and onion routing,” in *Proceedings. 1997 IEEE Symposium on Security and Privacy (Cat. No. 97CB36097)*. IEEE, 1997, pp. 44–54.
- [23] P. Winter, A. Edmundson, L. M. Roberts, A. Dutkowska-Żuk, M. Chetty, and N. Feamster, “How do tor users interact with onion services?” in *27th USENIX Security Symposium (USENIX Security 18)*, 2018, pp. 411–428.

- [24] A. Mani, T. Wilson-Brown, R. Jansen, A. Johnson, and M. Sherr, “Understanding tor usage with privacy-preserving measurement,” in *Proceedings of the Internet Measurement Conference 2018*, 2018, pp. 175–187.
- [25] P. Sirinam, M. Imani, M. Juarez, and M. Wright, “Deep fingerprinting: Undermining website fingerprinting defenses with deep learning,” in *Proceedings of the 2018 ACM SIGSAC conference on computer and communications security*, 2018, pp. 1928–1943.
- [26] M. S. Rahman, P. Sirinam, N. Mathews, K. G. Gangadhara, and M. Wright, “Tik-tok: The utility of packet timing in website fingerprinting attacks,” *arXiv preprint arXiv:1902.06421*, 2019.
- [27] S. Bhat, D. Lu, A. Kwon, and S. Devadas, “Var-cnn: A data-efficient website fingerprinting attack based on deep learning,” *arXiv preprint arXiv:1802.10215*, 2018.
- [28] A. Mitseva and A. Panchenko, “Stop, don’t click here anymore: boosting website fingerprinting by considering sets of subpages,” in *33rd USENIX Security Symposium (USENIX Security 24)*, 2024, pp. 4139–4156.
- [29] M. Nasr, A. Bahramali, and A. Houmansadr, “Deepcorr: Strong flow correlation attacks on tor using deep learning,” in *Proceedings of the 2018 ACM SIGSAC conference on computer and communications security*, 2018, pp. 1962–1976.
- [30] B. Greschbach, T. Pulls, L. M. Roberts, P. Winter, and N. Feamster, “The effect of dns on tor’s anonymity,” *arXiv preprint arXiv:1609.08187*, 2016.
- [31] Y. Sun, A. Edmundson, N. Feamster, M. Chiang, and P. Mittal, “Counter-raptor: Safeguarding tor against active routing attacks,” in *2017 IEEE symposium on security and privacy (SP)*. IEEE, 2017, pp. 977–992.
- [32] G. K. Gegenhuber, M. Maier, F. Holzbauer, W. Mayer, G. Merzdovnik, E. Weippl, and J. Ullrich, “An extended view on measuring tor as-level adversaries,” *Computers & Security*, vol. 132, p. 103302, 2023.
- [33] D. Lopes, J.-D. Dong, P. Medeiros, D. Castro, D. Barradas, B. Portela, J. Vinagre, B. Ferreira, N. Christin, and N. Santos, “Flow correlation attacks on tor onion service sessions with sliding subset sum,” in *NDSS*, 2024.
- [34] R. Jansen, F. Tschorsch, A. Johnson, and B. Scheuermann, “The sniper attack: Anonymously deanonymizing and disabling the tor network,” 2014.
- [35] R. Jansen, K. S. Bauer, N. Hopper, and R. Dingledine, “Methodically modeling the tor network,” in *CSET*, 2012.
- [36] C. Sendner, J. Stang, A. Dmitrienko, R. Wijewickrama, and M. Jadliwala, “Mirageflow: A new bandwidth inflation attack on tor,” in *NDSS*, 2024.
- [37] Z. Luo, J. Zhang, A. Neerati, and A. Kate, “Five minutes of ddos brings down tor: Ddos attacks on the tor directory protocol and mitigations,” in *Proceedings of the 21st European Conference on Computer Systems*, 2026, pp. 1314–1329.
- [38] J. K. Holland and N. Hopper, “Regulator: A straightforward website fingerprinting defense,” *arXiv preprint arXiv:2012.06609*, 2020.
- [39] M. W. Al Azad, H. Zahan, S. U. Taki, and S. Mastorakis, “Darkhorse: A udp-based framework to improve the latency of tor onion services,” in *2023 IEEE 48th Conference on Local Computer Networks (LCN)*. IEEE, 2023, pp. 1–6.

- [40] K. MacMillan, J. Holland, and P. Mittal, “Evaluating snowflake as an indistinguishable censorship circumvention tool,” *arXiv preprint arXiv:2008.03254*, 2020.
- [41] Z. Sun and V. Shmatikov, “Differential degradation vulnerabilities in censorship circumvention systems,” *arXiv preprint arXiv:2409.06247*, 2024.
- [42] A. Vilalonga, K. Gallagher, J. S. Resende, and H. Domingos, “Obscura: Enabling ephemeral proxies for traffic encapsulation in webrtc media streams against cost-effective censors,” *Proceedings on Privacy Enhancing Technologies*, 2026.
- [43] M. Casenove and A. Miraglia, “Botnet over tor: The illusion of hiding,” in *2014 6th International Conference on Cyber Conflict*. IEEE, 2014.
- [44] Rapid7, “Skynet, a tor-powered botnet straight from reddit,” <https://www.rapid7.com/blog/post/2012/12/06/skynet-a-tor-powered-botnet-straight-from-reddit/>, 2012.
- [45] Kaspersky Securelist, “Chewbacca – a new episode of tor-based malware,” <https://securelist.com/chewbacca/58192/>, 2013.
- [46] The Tor Project, “How to handle millions of new tor clients,” <https://blog.torproject.org/how-to-handle-millions-new-tor-clients/>, 2013.
- [47] Fortinet FortiGuard Labs, “Bricker bot – a silver lining to force accountability for iot security?” <https://www.fortinet.com/blog/threat-research/brickerbot>, 2017.
- [48] —, “Enemybot: A look into keksec’s latest ddos botnet,” <https://www.fortinet.com/blog/threat-research/enemybot-a-look-into-keksecs-latest-ddos-botnet>, 2022.
- [49] M. Li *et al.*, “Tpoti: A triplet-network-based obfuscated tor traffic identification,” in *IFIP Networking*, 2025.
- [50] P. Dodia, M. AlSabah, O. Alrawi, and T. Wang, “Exposing the rat in the tunnel: Using traffic analysis for tor-based malware detection,” in *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security*, 2022.
- [51] D. Oškera, J. Koumar, A. Pokorná, K. Jeřábek, and T. Čejka, “Botnet detection through periodic patterns in command-and-control network traffic,” in *IFIP/IEEE International Symposium on Integrated Network Management (CNSM)*, 2025.
- [52] G. Wu, X. Wang, and J. Zhang, “Peerg: A p2p botnet detection method based on representation learning and graph contrastive learning,” *Computers & Security*, vol. 140, p. 103775, 2024.
- [53] M. A. R. Putra, T. Ahmad, and D. P. Hostiadi, “B-cat: a model for detecting botnet attacks using deep attack behavior analysis on network traffic flows,” *Journal of Big Data*, vol. 11, p. 49, 2024.
- [54] B. Cebere, J. Fluere, S. Sebastián, D. Plohm, and C. Rossow, “Down to earth! guidelines for dga-based malware detection,” in *Proceedings of the 27th International Symposium on Research in Attacks, Intrusions and Defenses (RAID)*, 2024.
- [55] A. Drichel, M. Meyer, and U. Meyer, “Towards robust domain generation algorithm classification,” in *Proceedings of the 19th ACM Asia Conference on Computer and Communications Security (AsiaCCS)*, 2024.
- [56] Y. Xie, G. Gou, G. Xiong, Z. Li, and W. Xia, “Domeye: Detecting network covert channel of domain fronting with throughput fluctuation,” *Computers & Security*, vol. 144, p. 103976, 2024.
- [57] D. Barradas, C. Novo, B. Portela, S. Romeiro, and N. Santos, “Extending c2 traffic detection methodologies: From tls 1.2 to tls 1.3-enabled malware,” in *Proceedings of the 27th International Symposium on Research in Attacks, Intrusions and Defenses (RAID)*, 2024.

- [58] M. A. Hossain and M. S. Islam, “Hta-botdef: A novel hierarchical tree aggregation for scalable and privacy preserving botnet attack detection with federated learning,” *Journal of Information and Intelligence*, 2025.
- [59] I. Karunanayake, M. AlSabah, N. Ahmed, and S. Jha, “Examining the rat in the tunnel: Interpretable multi-label classification of tor-based malware,” *arXiv preprint arXiv:2401.xxxx*, 2024.
- [60] P. Tippe and A. Tippe, “Onion services in the wild: A study of deanonymization attacks,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [61] D. Liu and Y. Park, “Anonymous traffic detection based on feature engineering and reinforcement learning,” *Sensors*, vol. 24, no. 7, p. 2295, 2024.